icontec

NORMA TÉCNICA COLOMBIANA

NTC-ISO 22301

2019-11-20

Seguridad y resiliencia. Sistema de gestión de continuidad de negocio. Requisitos

E: Security and resilience. Business continuity management systems. Requirements

CORRESPONDENCIA: Esta norma es una adopción idéntica (IDT) por traducción de la norma ISO 22301:2019

DESCRIPTORES: continuidad de negocio; sistema de gestión; resiliencia; seguridad

I.C.S.: 03.100.01; 03.100.70

® ICONTEC 2019
Reservados todos los derechos. Ninguna parte de esta publicación puede ser reproducida o utilizada en cualquier forma o por cualquier medio, electrónico o mecánico incluyendo fotocopiado y microfilmación, sin permiso por escrito del editor.

Editada por ICONTEC. Apartado 14237 Bogotá, D.C. –Tel. (571) 6078888

Prohibida su reproducción I Editada 2019-11-20



PRÔLOGO

El Instituto Colombiano de Normas Técnicas y Certificación, ICONTEC, es el organismo nacional de normalización, según el Decreto 1595 de 2015.

ICONTEC es una entidad de carácter privado, sin ánimo de lucro, cuya Misión es fundamental para brindar soporte y desarrollo al productor y protección al consumidor. Colabora con el sector gubernamental y apoya al sector privado del país, para lograr ventajas competitivas en los mercados interno y externo.

La representación de todos los sectores involucrados en el proceso de Normalización Técnica está garantizada por los Comités Técnicos y el período de Consulta Pública, este último caracterizado por la participación del público en general.

La NTC-ISO 22301 fue ratificada por el Consejo Directivo de 2019-11-20.

Esta norma está sujeta a ser actualizada permanentemente con el objeto de que responda en todo momento a las necesidades y exigencias actuales.

A continuación, se relacionan las empresas que colaboraron en el estudio de esta norma a través de su participación en el Comité Técnico 205 - Seguridad de la sociedad y resiliencia.

AC TRUST
BANCO AGRARIO
BCM CONSULTORES
FRONTERA ENERGY
GAMA CONSULTING
ICONTEC - REGIONAL BOGOTÁ
PROMIGAS
STRATEGY CONSULTING SAS

Además de las anteriores, en Consulta Pública el Proyecto se puso a consideración de las siguientes empresas:

ACERÍAS DE COLOMBIA ACESCO S.A.S.
AES GESTIOM LTDA
ANGELUS SEGURIDAD LTDA
ASIS INTERNATIONAL, CAPÍTULO 225 BOGOTÁ.
ASOBANCARIA
BANCO CENTRAL DE RESERVA
BANCO COLPATRIA
BANCO DAVIVIENDA
BANCO DE LA REPÚBLICA
BIGXPERIENCE S.A.S.
BPM GLOBAL SOLUCIONES S.A.S.
BUSINESS SOLUTIONS CONSULTANTS SAS
CINTEL
COLPENSIONES
COLVISEG LTDA
COMFENALCO ANTIOQUIA
COMUNIDAD COLADCA - COMUNIDAD LATINOAMERICANA DE CONSULTORES Y ASESORES EN GESTIÓN DE RIESGOS Y SEGURIDAD.
DIRECCIÓN NACIONAL DE INTELIGENCIA
ECOPETROL
EMPRESAS PUBLICAS DE MEDELLIN E.S.P
ETICA Y TECNOLOGIA S.A.S.
EXPERIAN S.A.

FUNDICOM FUNDICIONES Y COMPONENTES AUTOMOTORES S.A.S
FUNDICOM S.A.S
GESTIÔN & ESTRATEGIA SAS
GRUPO ATLAS DE SEGURIDAD INTEGRAL
HONOR SERVICIOS DE SEGURIDAD LTDA.
ICONTEC - EVALUACIÔN DE LA CONFORMIDAD
!SOLUCIONES SAS
ITEAM LTDA
KPMG
MARSH RISK CONSULTING
MS CONSULTORES
PFIZER
PRICEWATERHOUSECOOPERS AG
PROFESIONAL INDEPENDIENTE ALEJANDRO PEREZ BOLIVAR
PROFESIONAL INDEPENDIENTE ARISTIDES BALDOMERO CONTRERAS FERNANDEZ
PROFESIONAL INDEPENDIENTE GIOVANNY VARGAS GIL
PROFESIONAL INDEPENDIENTE JAIME NAVARRO CASTAÑO
PROFESIONAL INDEPENDIENTE JORGE EDUARDO JARAMILLO ISAZA
PROFESIONAL INDEPENDIENTE JUAN LOBO TORRES
SGS COLOMBIA SAS
SMART IT SOLUTIONS
SOCIETAL SECURITY SAS
SUPERINTENDENCIA DE VIGILANCIA Y SEGURIDAD PRIVADA
THOMAS GREG & SONS DE COLOMBIA S.A.
THOMAS MANEJO TECNICO DE INFORMACION
TOTAL SOLUTIONS GROUP SAS
UNIDAD EJECUTORA DE SANEAMIENTO DEL VALLE DEL CAUCA- UES
VEOLIA HOLDING COLOMBIA SA
WILLIS CONSULTING

ICONTEC cuenta con un Centro de Información que pone a disposición de los interesados normas internacionales, regionales y nacionales y otros documentos relacionados.

DIRECCIÔN DE NORMALIZACIÔN

CONTENIDO

Página

1. OBJETO Y CAMPO DE APLICACIÔN 1

2. REFERENCIAS NORMATIVAS 1

3. TÉRMINOS Y DEFINICIONES 2

4. CONTEXTO DE LA ORGANIZACIÔN 7

4.1 COMPRENDER LA ORGANIZACIÔN Y SU CONTEXTO 7

4.2 COMPRENDER LAS NECESIDADES Y EXPECTATIVAS DE LAS PARTES INTERESADAS 7

4.3 DETERMINAR EL ALCANCE DEL SISTEMA DE GESTIÔN DE CONTINUIDAD DE NEGOCI0 8

5. LIDERAZGO 8

6. PLANEACIÔN 10

6.1 ACCIONES PARA ABORDAR LOS RIESGOS Y LAS OPORTUNIDADES 10

6.2 OBJETIVOS PARA LA CONTINUIDAD DE NEGOCIO Y LA PLANEACIÔN PARA LOGRARLOS 10

6.3 PLANEACIÔN DE CAMBIOS EN EL SISTEMA DE GESTIÔN DE CONTINUIDAD DE NEGOCIO 11

7. SOPORTE 11

7.1 RECURSOS 11

7.2 COMPETENCIA 12

Página

7.3 CONOCIMIENTO 12

7.4 COMUNICACIÔN 12

7.5 INFORMACIÔN DOCUMENTADA 12

8. OPERACIÔN 14

8.1 PLANEACIÔN Y CONTROL OPERACIONAL. 14

8.2 ANËLISIS DE IMPACTO AL NEGOCIO Y EVALUACIÔN DE RIESGOS 14

8.3 ESTRATEGIAS PARA LA CONTINUIDAD DE NEGOCIO Y SOLUCIONES 15

8.4 PLANES Y PROCEDIMIENTOS PARA LA CONTINUIDAD DE NEGOCIO 16

8.5 PROGRAMA DE EJERCICIOS 19

8.6 EVALUACIÔN DE LA DOCUMENTACIÔN Y CAPACIDAD DE CONTINUIDAD DE NEGOCIO 20

9. EVALUACIÔN DEL DESEMPEÑO 20

9.1 MONITOREO, MEDICIÔN, ANËLISIS Y EVALUACIÔN 20

9.2 AUDITORÎA INTERNA 21

9.3 REVISIÔN POR LA DIRECCIÔN 22

1Q. MEJORAMIENTO 23

10.1 NO CONFORMIDAD Y ACCIÔN CORRECTIVA 23

10.2 MEJORAMIENTO CONTINUO 24

BIBLIOGRAFÎA 25

DOCUMENTO DE REFERENCIA 26

0. INTRODUCCIÔN

0.1 GENERALIDADES

Este documento especifica la estructura y los requisitos para implementar y mantener un sistema de gestión de continuidad de negocio (SGCN) que desarrolle una continuidad de negocio que corresponda al importe y tipo de impacto que la organización puede o no asumir después de una interrupción.

Los resultados de mantener un SGCN están determinados por los requisitos legales, legislativos, organizacionales e industriales, los productos y servicios ofrecidos, los procesos utilizados, el tamaño y la estructura de la organización, y los requisitos de sus partes interesadas.

Un SGCN enfatiza la importancia de:

- entender las necesidades de la organización y la urgencia de establecer políticas y objetivos para la continuidad de negocio;
- operar y mantener los procesos, la capacidad y los esquemas de respuesta para asegurar que la organización sobreviva a las interrupciones;
- monitorear y revisar el desempeño y la eficacia del SGCN;
- el mejoramiento continuo basado en mediciones cuantitativas y cualitativas.

Un SGCN, como cualquier otro sistema de gestión, incluye los siguientes componentes:

a) política;

b) personal competente con responsabilidades específicas;

c) procesos de gestión con relación a:

   1) política;

   2) planeación;

   3) implementación y operación;

   4) evaluación del desempeño;

   5) revisión por la dirección;

   6) mejoramiento continuo;

d) información documentada que soporte el control operativo y permita la evaluación del desempeño.

0.2 BENEFICIOS DE UN SISTEMA DE GESTIÔN DE CONTINUIDAD DE NEGOCIO

El propósito de un SGCN es prepararse para brindar y mantener los controles, y las capacidades para gestionar el total de la organización para seguir operando durante una interrupción. Para lograr esto, la organización debe:

a) desde una perspectiva empresarial:

   1) apoyar sus objetivos estratégicos;

   2) crear una ventaja competitiva;

   3) proteger y realzar su reputación y credibilidad;

   4) contribuir a la resiliencia organizacional;

b) desde una perspectiva financiera:

   1) reducir la exposición legal y financiera;

   2) reducir los costos directos e indirectos de las interrupciones;

c) desde una perspectiva de las partes interesadas:

   1) proteger la vida, la propiedad y el medio ambiente;

   2) considerar las expectativas de las partes interesadas;

   3) confiar en las capacidades de la organización para tener éxito;

d) desde una perspectiva de los procesos internos:

   1) mejorar su capacidad para seguir siendo efectivos durante las interrupciones;

   2) demostrar un control proactivo de los riesgos de manera eficaz y eficiente;

   3) abordar las vulnerabilidades operativas.

0.3 CICLO PLANEAR - HACER - VERIFICAR- ACTUAR (PHVA)

Este documento aplica el ciclo Planear (establecer), Hacer (implementar y operar), Verificar (monitorear y revisar) y Actuar (mantener y mejorar) para implementar, mantener y mejorar de manera continua la eficacia de un SGCN de una organización.

Esto garantiza un nivel de consistencia con otras normas de sistemas de gestión, tales como, ISO 9001, ISO 14001, ISO/IEC 20000-1, ISO/IEC 27001 e ISO 28000, apoyando así la implementación y la operación coherentes e integradas con otros sistemas de gestión relacionados.

De acuerdo con el ciclo PHVA, los numerales del 4 al 10, abarcan los siguientes componentes:

- Numeral 4: introduce los requisitos necesarios para establecer el contexto del SGCN que puede aplicarse a la organización, así como las necesidades, los requisitos y el alcance.

- Numeral 5: resume los requisitos específicos del papel de la alta dirección en el SGCN, y como, a través de la declaración de las políticas, los líderes comunican claramente sus expectativas a la organización.

- Numeral 6: describe los requisitos para establecer los objetivos estratégicos y los principios rectores para el SGCN en su totalidad.

- Numeral 7: apoya las operaciones del SGCN relacionadas con el establecimiento de las competencias y la comunicación reiterativa, según sea necesario, con las partes interesadas, al tiempo que se documenta, controla, mantiene y conserva la información documentada requerida.

- Numeral 8: define las necesidades de continuidad de negocio, determina como abordarlas y desarrolla procedimientos para gestionar la organización durante una interrupción.

- Numeral 9: resume los requisitos necesarios para medir el desempeño de la continuidad de negocio, la conformidad del SGCN con este documento y dirigir la revisión por la dirección.

- Numeral 10 identifica y reacciona antes las no conformidades del SGCN, y el mejoramiento continuo a través de las acciones correctivas.

0.5 CONTENIDO DE ESTE DOCUMENTO

Este documento cumple con los requisitos de ISO para las normas de sistema de gestión. Estos requisitos incluyen una estructura de alto nivel, texto básico idéntico y términos comunes con definiciones esenciales, diseñadas para beneficiar a los usuarios que implementen varias normas de sistemas de gestión.

Este documento no incluye requisitos específicos de otros sistemas de gestión, aunque sus elementos pueden alinearse o integrarse con los de otros sistemas de gestión.

Este documento contiene requisitos que pueden ser usados por una organización para implementar un SGCN y evaluar la conformidad. Una organización que desee demostrar su conformidad con este documento, puede hacerlo de la siguiente manera:

- elaborar una autodeterminación o una auto-declaración; o

- lograr la confirmación de su conformidad por las partes que tengan interés en la organización, como los clientes; o

- lograr la confirmación de su auto-declaración por las partes externas de la organización; o

- lograr la certificación o registro de su SGCN por una organización externa.

Los numerales del 1 al 3 exponen el alcance, las referencias normativas y, los términos y definiciones que se aplican al uso de este documento. Los numerales del 4 al 1O contienen los requisitos que deben utilizarse para la evaluar la conformidad de este documento.

En este documento, se usan las siguientes formas verbales:

a) "debe" indica un requisito;

b) "debería" indica una recomendación;

c) "puede" indica en algunas ocasiones un permiso y, en otras, posibilidad o capacidad.

La información marcada como "NOTA" es para la orientación en la comprensión o clarificación del requisito asociado. Las "notas a la entrada" usadas en el numeral 3 proporcionan información adicional que complementan la información terminológica y pueden contener disposiciones relacionadas con el uso de un término.

SEGURIDAD Y RESILIENCIA.
SISTEMA DE GESTIÓN DE CONTINUIDAD DE NEGOCIO. REQUISITOS

1. OBJETO Y CAMPO DE APLICACIÓN

Este documento especifica los requisitos ¡Jara implementar, mantener y mejorar un sistema de gestión para protegerse, reducir la probabilidad de ocurrencia de, prepararse, responder y recuperarse de las interrupciones cuando estas surjan.

Los requisitos que se especifican en este documento son genéricos y están destinados para ser aplicados en todas las organizaciones, o partes de estas, sin tener en cuenta el tipo, tamaño o naturaleza de la organización. El grado de aplicación de estos requisitos depende del ambiente operativo y la complejidad de la organización.

Este documento es aplicable a todos los tipos y tamaños de organizaciones que:

a) implementen, mantengan y mejoren un SGCN;

b) procuren asegurar la conformidad con las políticas de continuidad de negocio establecidas;

c) tengan la capacidad de continuar ofreciendo sus productos y servicios en una aceptable capacidad predefinida durante una interrupción;

d) procuren mejorar su resiliencia a través de la aplicación efectiva del SGCN.

Este documento puede usarse para evaluar la capacidad de la organización para satisfacer sus propias obligaciones y necesidades de continuidad de negocio.

2. REFERENCIAS NORMATIVAS

Los siguientes documentos se citan en el texto de tal manera que parte o todo su contenido constituye requisito de este documento. Para las referencias con fecha, solo se aplica la edición citada. Para las referencias sin fecha, se aplica la última edición del documento referenciado (incluidas las enmiendas).

ISO 22300, *Security and resi/ience. Vocabulary*

3. TÉRMINOS Y DEFINICIONES

Para los efectos de este documento, se aplican los términos y definiciones dados en ISO 22300.

ISO e IEC mantienen bases de datos terminológicas para su uso en la estandarización en las siguientes direcciones:

- Plataforma de navegación en línea de ISO: disponible en https://www.iso.org/obp
- Electropedia IEC: disponible en http://www.electropedia.org/

NOTA Los términos y definiciones que se mencionan a continuación reemplazan los que figuran en ISO 22300:2018

3.1 actividad ***(activity).*** Conjunto de una o más tareas con un resultado definido.

[FUENTE: ISO 22300: 2018, 3.1, modificado - Se reemplazó la definición y el ejemplo se eliminó]

3.2 auditoría ***(audit).*** *Proceso* {3.26) sistemático, independiente y documentado para obtener evidencia y evaluarla objetivamente para determinar en qué medida se cumplen los criterios de auditoría.

Nota 1 a *la entrada:* Una auditoría puede ser interna (primera parte) o externa (segunda o tercera parte), y puede ser combinada (dos o más disciplinas).

Nota 2 a *la entrada:* Una auditoría interna es llevada a cabo por la misma *organización* (3.21) o por una parte externa en su nombre.

Nota 3 a *la entrada:* Las evidencias y los criterios de auditoría se definen en la norma ISO 19011.

Nota 4 a *la entrada:* Los elementos fundamentales de una auditoría incluyen la determinación de la *conformidad* (3.7) de un objeto de acuerdo con un procedimiento llevado a cabo por personal que no sea responsable del objeto auditado.

Nota 5 a la entrada: Una auditoría interna puede usarse para la revisión por la dirección y otros fines internos y puede ser la base para la declaración de conformidad de una organización. La independencia se demuestra por la autonomía de la responsabilidad de la *actividad* (3.1) que se audita. Las auditorías externas incluyen auditorías de segundas y terceras partes. Las auditorías de segundas partes son llevadas a cabo por las partes que tienen intereses en la organización, tales como clientes, u otras personas en su nombre. Las auditorías de terceras partes se llevan a cabo por organizaciones de auditoría independientes y externas, tales como aquellas que proveen los certificados o registros de conformidad o entes gubernamentales.

Nota 6 a *la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO. Se modificó la definición original adicionando las Notas 4 y 5 a la entrada.

3.3 continuidad de negocio ***(business continuity).*** Capacidad de una *organización* (3.21) de continuar la oferta de *productos* y *servicios* (3.27) dentro de un período de tiempo aceptable a una capacidad predefinida durante una interrupción (3.1 0) .

[Fuente: ISO 22300: 2018, 3.24, modificado - Se reemplazó la definición]

3.4 plan de continuidad de negocio ***(business continuity plan).*** *Información documentada* (3.11) que orienta a una *organización* (3.21) para responder una *interrupción* (3.1 0) y reanudar, recuperar y restaurar la oferta de *productos y servicios* (3.27) de acuerdo con sus *objetivos* (3.20) de *continuidad de negocio* (3.3).

[Fuente: ISO 22300:2018, 3.26, modificado - Se reemplazó la definición y se eliminó la nota 1 a la entrada].

3.5 análisis de impacto al negocio *(business impact análisis,* BIA}. *Proceso* (3.26) en el que se analiza el *impacto* (3.13) de una *interrupción* (3.1 O) conforme avanza el tiempo, en la *organización* (3.21).

Nota 1 a *la entrada* El resultado es una declaración y justificación de los *requisitos* (3.28) de la *continuidad de negocio* (3.3).

[Fuente: ISO 22300:2018, 3.27, modificado - Se reemplazó la definición y se incluyó la nota 1 a la entrada].

3.6 competencia *(competence).* Habilidad de aplicar los conocimientos y las habilidades para lograr los resultados deseados.

Nota 1 a *la entrada* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.7 conformidad *(conformity).* Cumplimiento de un *requisito* (3.28)

Nota 1 a *la entrada* Este constituye uno de los términos comunes y definiciones básicas de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.8 mejoramiento continuo *(continua/ improvement).* *Actividad* (3.1) recurrente para mejorar el *desempeño* (3.23).

Nota 1 a *la entrada* Este constituye uno de los términos comunes y definiciones básicas de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.9 acción correctiva *(corrective action).* Acción para eliminar la causa de una *no conformidad* (3.19) y prevenir su recurrencia.

Nota 1 a *la entrada:* Este constituye uno de los términos comunes y definiciones básicas de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.10 interrupción *(disruption).* *Incidente* (3.14), bien sea esperado o no, que causa una alteración negativa y no planeada de la oferta esperada de los *productos y servicios* (3.27) de acuerdo con los *objetivos* (3.20) de la *organización* (3.21).

[Fuente: ISO 22300:2018, 3.70, modificado - Se reemplazó la definición].

3.11 información documentada *(documented information).* Información que una *organización* (3.21) tiene que controlar y mantener, y el medio que la contiene.

Nota 1 a *la entrada:* la información documentada puede estar en cualquier formato y medio, y puede provenir de cualquier fuente.

Nota 2 a *la entrada:* la información documentada puede hacer referirse a:

- *el sistema de gestión* (3.16), incluidos los *procesos* (3.26) relacionados;
- la información generada para que la organización opere (documentación);
- la evidencia de los resultados alcanzados (registros).

Nota 2 *a la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.12 eficacia (effectiveness). Grado en el cual se realizan las *actividades* (3.1) planeadas y se logran los resultados esperados.

Nota 1 *a la entrada:* Este constituye uno de los términos comunes y definiciones esencialesde la estructura de alto nivel de las normas de los sistemas de gestión *de* ISO.

3.13 impacto (impact). Resultado de una *interrupción* (3.1 O) que afecta los *objetivos* (3.20).

[Fuente: ISO 22300:2018, 3.107, modificado- Se reemplazó la definición]

3.14 incidente (incident). Evento que puede ser, o podría conducir a una *interrupción* (3.1 O), pérdida, emergencia o crisis.

[Fuente: ISO 22300:2018, 3.111, modificado - Se reemplazó la definición].

3.15 parte interesada (interested party)- **término preferido**
accionista (stakeholder) **- término admitido**

Persona u *organización* {3.21) que puede afectar, verse afectada o percibirse como afectada por una decisión o *actividad* (3. 1).

Ejemplo: Clientes, propietarios, personal de una organizac1ón, proveedores, banca, legisladores, sindicatos, socios o sociedad que pueden incluir competidores o grupos de presión con intereses opuestos.

Nota 1 *a la entrada:* Una persona encargada puede ser una parte interesada.

Nota 2 *a la entrada:* Se consideran partes interesadas las comunidades impactadas y las poblaciones locales.

Nota 3 *a la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO. Se modificó la definición original adicionando un ejemplo y las notas a la entrada 1 y 2.

3.16 sistema de gestión (management system). Conjunto de elementos de una *organización* (3.21) interrelacionados o que interactúan para establecer *políticas* (3.24), *objetivos* (3.20) y *procesos* (3.26) para lograr esos objetivos.

Nota 1 *a la entrada:* Un sistema de gestión puede tratar una sola o varias disciplinas.

Nota 2 *a la entrada:* Los elementos del sistema incluyen la estructura de la organización, los roles y responsabilidades, la planeación y la operación.

Nota 3 a *la entrada:* El alcance de un sistema de gestión puede incluir la totalidad de la organización, funciones o secciones específicas e identificadas de la organización, secciones específicas e identificadas de la organización, o una o más funciones dentro de un grupo de organizaciones.

Nota 4 *a la entrada* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.17 medición (measurement). *Proceso* (3.26) para determinar un valor.

Nota 1 *a la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.18 monitoreo ***(monitoring).*** Determina el estado de un sistema, un *proceso* (3.26) o una *actividad* (3.1).

Nota 1 *a la entrada:* Para determinar el estado, puede ser necesario comprobar, supervisar u observar de manera critica.

Nota 2 *a la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.19 no conformidad ***(non conformity).*** Incumplimiento de un *requisito* (3.28)

Nota 1 *a la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.20 objetivo ***(objective).*** Resultado a lograr.

Nota 1 a *la entrada:* Un objetivo puede ser estratégico, táctico u operacional.

Nota 2 a *la entrada:* Los objetivos pueden relacionarse con diferentes disciplinas (como objetivos financieros, de salud y seguridad, y ambientales), y pueden aplicarse en diferentes niveles (como estratégicos, de toda la organización, de proyecto, de producto y de *proceso* (3.26)).

Nota 3 *a la entrada:* Un objetivo puede expresarse de varias maneras, por ejemplo, como un resultado deseado, como un propósito, como un criterio operativo, como un objetivo de *continuidad de negocio* (3.3), o mediante el uso de palabras similares (por ejemplo, objeto, meta, propósito).

Nota 4 *a la entrada:* En el contexto de los *sistemas de gestión* (3.16) de continuidad de negocio, la *organización* (3.21) establece los objetivos de continuidad de negocio, de acuerdo con las *políticas* (3.24) de continuidad de negocio para lograr los resultados específicos.

Nota 5 a *la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.21 organización ***(organization).*** Persona o grupo de personas que tiene sus propias funciones con responsabilidades, autoridad y relaciones para lograr sus *objetivos* (3.20).

Nota 1 *a la entrada:* El concepto de organización, incluye pero no se limita a, un comerciante independiente, una compañia, una corporación, una firma, una empresa, una autoridad, una asociación, una organización benéfica o institución, o parte o combinación de los mismos, bien sea incorporada o no, pública o privada.

Nota 2 a *la entrada:* Para organizaciones con más de una unidad operativa, una sola unidad operativa puede definirse como organización.

Nota 3 a *la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO. Se modificó la definición original adicionando la nota a la entrada 2.

3.22 subcontratar ***(outsource).*** Realizar un acuerdo donde una *organización* (3.21) externa realiza parte de una función o *proceso* (3.26) de la organización.

Nota 1 *a la entrada:* Una organización externa esta por fuera del alcance de un *sistema de gestión* (3.16), aunque la función o el proceso subcontratado este dentro del alcance.

Nota 2 a *la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.23 desempeño ***(performance).*** Resultado medible.

Nota 1 a *la entrada:* el desempeño puede estar relacionado con hallazgos cuantitativos o cualitativos.

Nota 2 a *la entrada:* el desempeño puede relacionarse con *actividades* (3.1) directivas, *procesos* (3.26), productos (incluyendo servicios), sistemas u *organizaciones* (3.21).

Nota 3 a *la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.24 política *(policy).* Propósitos y dirección de una *organización* (3.21), como expresa formalmente la *alta dirección* (3.31).

Nota 1 a *la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.25 actividad priorizada *(prioritized activity).* Actividad (3.1) a la que se le da urgencia con el fin de evitar *impactos* (3.13) indeseables para el negocio durante una *interrupción* (3.1 O).

[Fuente: ISO 22300:2018, 3.176, modificado - Se reemplazó la definición y se eliminó la nota a la entrada 1].

3.26 proceso *(process).* Conjunto de *actividades* (3.1) interrelacionadas o que interactúan las cuales transforman entradas en salidas.

Nota 1 a *la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.27 Productos y servidos *(product and service).* Salida o resultado que provee una *organización* (3.21) a las *partes interesadas* (3.15).

Ejemplo Productos manufacturados, seguro de automóvil, servicios de enfermería.

[Fuente: ISO 22300; 2018, 3.181, El término "productos o servicios" se reemplazó por "productos y servicios" y se reemplazó la definición].

3.28 requisito *(requirement).* Necesidad o expectativa que se indica, generalmente implícita u obligatoria.

Nota 1 a *la entrada:* generalmente implícita significa que es costumbre o práctica común de la *organización* (3.21) y de las *partes interesadas* (3.15) que la necesidad o expectativa en consideración es implícita.

Nota 2 a *la entrada:* un requisito específico es aquel que se indica, por ejemplo, en la *información documentada* (3.11).

Nota 3 a *la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

3.29 recursos *(resource).* Todos los activos (incluyendo planta y equipo); personas, habilidades, tecnología, instalaciones, provisiones, suministros e información (bien sea electrónica o no) que una *organización* (3.21) posee y que tienen que tener disponibilidad para usarse cuando sea necesario, con el fin de operar y lograr su *objetivo* (3.20).

[Fuente: ISO 22300: 2018, 3.103, modificado - Se reemplazó la definición].

3.30 riesgo *(risk).* Efecto de la incertidumbre en los *objetivos* (3.20).

Nota 1 *a la entrada:* Un efecto es una desviación de lo esperado - positivo o negativo.

Nota 2 *a la entrada:* La incertidumbre es el estado, incluso parcial, de la deficiencia en la información relacionada, conocida y comprendida, de un evento, su consecuencia y probabilidad.

Nota 3 *a la entrada:* El riesgo se caracteriza a menudo, por la referencia a posibles "eventos" y "consecuencias" (como se define en la guía 73 de ISO), o la combinación de ambos.

Nota 4 *a la entrada:* El riesgo se expresa a menudo en términos de la combinación de las consecuencias de un evento (incluidos los cambios en las circunstancias) y la asociada probabilidad (como se define en la guía 73 de ISO) de ocurrencia.

Nota 5 *a la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO. Se modificó la definición adicionando "en los objetivos" para ser consistentes con la NTC-ISO 31000.

3.31 alta dirección *(top management).* Persona o grupo de personas que dirigen y controlan una *organización* (3.21) en su más alto nivel.

Nota 1 *a la entrada:* La alta dirección tiene el poder de delegar y proveer *recursos* (3.29) dentro de la organización.

Nota 2 *a la entrada:* Si el alcance de un *sistema de gestión* (3.16) cubre solo una parte de la organización, entonces la alta dirección se refiere a aquellos que dirigen y controlan esa parte de la organización.

Nota 3 *a la entrada:* Este constituye uno de los términos comunes y definiciones esenciales de la estructura de alto nivel de las normas de los sistemas de gestión de ISO.

4. CONTEXTO DE LA ORGANIZACIÓN

4.1 COMPRENDER LA ORGANIZACIÓN Y SU CONTEXTO

La organización debe determinar las cuestiones externas e internas que sean relevantes para su propósito y que afecten su capacidad para lograr el (los) resultado(s) deseado(s) de su SGCN.

Nota Estas cuestiones se verán influenciados por los objetivos generales de la organización, sus productos y servicios y el importe y tipo de riesgo que pueda o no asumir.

4.2 COMPRENDER LAS NECESIDADES Y EXPECTATIVAS DE LAS PARTES INTERESADAS

4.2.1 Generalidades

Cuando se establece un SGCN, la organización debe determinar:

a) las partes interesadas que son relevantes para el SGCN;

b) los requisitos relevantes para esas partes interesadas.

4.2.2 Requisitos legales y reglamentarios

La organización debe:

a) implementar y mantener procesos para identificar, tener acceso y evaluar los requisitos legales y reglamentarios vigentes relacionados con la continuidad de sus productos y servicios, actividades y recursos;

b) asegurar de que estos requisitos regulatorios, legales y cualquier otro, vigentes, sean tenidos en cuenta en la implementación y mantenimiento del SGCN;

c) documentar esta información y mantenerla actualizada.

4.3 DETERMINAR EL ALCANCE DEL SISTEMA DE GESTIÓN DE CONTINUIDAD DE NEGOCIO

4.3.1 Generalidades

La organización debe determinar los límites y la aplicabilidad del SGCN para establecer su alcance.

Cuando se determina el alcance, la organización debe considerar:

a) las cuestiones externas e internas a los que se hizo referencia en el numeral 4.1;

b) los requisitos a los que se hizo referencia en el numeral 4.2;

c) su misión, metas y obligaciones internas y externas.

El alcance debe estar disponible como información documentada.

4.3.2 Alcance del sistema de gestión de continuidad de negocio

La organización debe:

a) establecer las partes de la organización que serán incluidas en el SGCN, teniendo en cuenta su locación, tamaño, naturaleza y complejidad;

b) identificar los productos y servicios que se incluirán en el SGCN.

Cuando se define el alcance del **SGCN,** la organización debe documentar y aclarar las exclusiones. Estas, no deben afectar la responsabilidad y capacidad de la organización para brindar la continuidad de negocio según lo determinado en el análisis de impacto al negocio o la evaluación del riesgo y los requisitos regulatorios y legales vigentes.

4.4 SISTEMA DE GESTIÓN DE CONTINUIDAD DE NEGOCIO

La organización debe establecer, implementar, mantener y mejorar de manera continua el SGCN, incluyendo los procesos necesarios y sus interrelaciones, de acuerdo con los requisitos de este documento.

5. LIDERAZGO

5.1 LIDERAZGO Y COMPROMISO

La alta dirección debe demostrar liderazgo y compromiso con respecto al SGCN de la siguiente forma:

a) asegurando que las políticas y los objetivos de continuidad de negocio están establecidos y son compatibles con la dirección estratégica de la organización;

b) asegurando la integración de los requisitos del SGCN en los procesos empresariales de la organización;

c) asegurando que los recursos necesarios para el SGCN se encuentran disponibles;

d) comunicando la importancia de la continuidad de negocio efectiva de acuerdo con los requisitos del SGCN;

e) asegurando que el SGCN logre el (los) objetivo(s) deseado(s);

f) dirigiendo y apoyando el personal que contribuye a la eficacia del SGCN;

g) promoviendo el mejoramiento continuo;

h) apoyando otras funciones gerenciales importantes para demostrar liderazgo y compromiso que aplican a sus áreas de responsabilidad.

Nota La referencia a negocio en este documento puede interpretarse en términos generales para referirse a aquellas actividades que son fundamentales para los propósitos de la existencia de la organización.

5.2 POLÎTICAS

5.2.1 Establecer la política de continuidad de negocio

La alta dirección debe establecer una política de continuidad de negocio que:

a) sea apropiada a los propósitos de la organización;

b) proporcione una estructura para establecer los objetivos de continuidad de negocio;

c) incluya el compromiso para satisfacer los requisitos vigentes;

d) incluya el compromiso para el mejoramiento continuo del SGCN.

5.2.2 Comunicar la política de continuidad de negocio

La política de continuidad de negocio debe:

a) estar disponible como información documentada:

b) comunicarse dentro de la organización;

c) estar disponible para las partes interesadas, según convenga.

5.2.3 Funciones, responsabilidades y autoridad

La alta dirección debe asegurarse de que la responsabilidad y autoridad para los roles importantes se asignen y se comuniquen dentro de la organización.

La alta dirección debe asignar la responsabilidad y autoridad para:

a) asegurar de que el SGCN cumple con los requisitos de este documento;

b) informar acerca del desempeño del SGCN a la alta dirección.

6. PLANEACIÓN

6.1 ACCIONES PARA ABORDAR LOS RIESGOS Y LAS OPORTUNIDADES

6.1.1 Determinar los riesgos y las oportunidades

Al realizar la planeación del SGCN, la organización debe considerar las cuestiones a las que se hace referencia en el numeral 4.1 y los requisitos del numeral 4.2 y determinar los riesgos y las oportunidades que necesitan abordarse para:

a) asegurarse que el SGCN pueda lograr el (los) resultado(s) deseado(s);

b) prevenir o reducir, los resultados indeseados;

c) lograr el mejoramiento continuo.

6.1.2 Abordar riesgos y oportunidades

La organización debe planear:

a) acciones para abordar los riesgos y las oportunidades;

b) como:

1) integrar e implementar las acciones en los procesos del SGCN (ver numeral 8.1)

2) evaluar la eficacia de estas acciones (ver numeral 9.1)

Nota Los riesgos y las oportunidades se relacionan con la eficacia del sistema de gestión. Los riesgos relacionados con la interrupción del negocio se abordan en el numeral 8.2.

6.2 OBJETIVOS PARA LA CONTINUIDAD DE NEGOCIO Y LA PLANEACIÓN PARA LOGRARLOS

6.2.1 Establecer los objetivos para la continuidad de negocio

La organización debe establecer los objetivos para la continuidad de negocio en las funciones y niveles relevantes.

Los objetivos para la continuidad de negocio deben:

a) ser consistentes con la política de continuidad de negocio;

b) ser medibles (si es viable);

c) tener en cuenta los requisitos vigentes (ver numerales 4.1 y 4.2);

d) monitorearse;

e) comunicarse;

f) actualizarse según convenga.

La organización debe conservar información documentada sobre los objetivos para la continuidad de negocio.

6.2.2 Determinar los objetivos para la continuidad de negocio

Al planificar cómo lograr los objetivos para la continuidad de negocio, la organización debe determinar:

a) qué se va a hacer;

b) qué recursos se requerirán;

c) quién será responsable;

d) cuándo se finalizará;

e) cómo se evaluarán los resultados.

6.3 PLANEAICIÔN DE CAMBIOS EN EL SISTEMA DE GESTIÔN DE CONTINUIDAD DE NEGOCIO

Cuando la organización determine la necesidad de cambios en el SGCN, incluyendo aquellos identificados en el numeral 10, estos cambios se deben llevar a cabo de manera planificada.

La organización debe considerar:

a) el propósito del cambio y sus consecuencias potenciales;

b) la integridad con el SGCN;

c) la disponibilidad de recursos;

d) la asignación o reasignación de responsabilidades y autoridad.

7. SOPORTE

7.1 RECURSOS

La organización debe determinar y brindar los recursos necesarios para el establecimiento, implementación, mantenimiento y mejora continua del SGCN.

7.2 COMPETENCIA

La organización debe:

a) determinar las competencias necesarias de las personas que trabajan bajo su propio control y que afecta su desempeño de continuidad de negocio;

b) asegurar que estas personas son competentes basándose en la educación, formación o experiencia apropiadas;

c) cuando sea aplicable, tomar acciones para adquirir las competencias necesarias, y evaluar la eficacia de las acciones tomadas;

d) conservar información documentada como evidencia de las competencias.

Nota Las acciones aplicables pueden incluir, por ejemplo, la formación, de tutoría, o la reasignación de personas empleadas actualmente; o la contratación de personas competentes.

7.3 CONOCIMIENTO

Las personas que trabajen bajo el control de la organización deben tener en cuenta:

a) la política de continuidad de negocio;

b) su contribución para la eficacia del SGCN, incluyendo los beneficios de mejorar el desempeño de la continuidad de negocio;

c) las implicaciones de las no conformidades con los requisitos del SGCN;

d) sus funciones y responsabilidades antes, durante y después de las interrupciones.

7.4 COMUNICACIÓN

La organización debe determinar las comunicaciones internas y externas pertinentes para el SGCN, que incluyan:

a) qué comunicar;

b) cuando comunicar;

c) a quién comunicar;

d) como comunicar;*22301*

e) quien comunicará.

7.5 INFORMACIÓN DOCUMENTADA

7.5.1 Generalidades

El SGCN de la organización debe incluir:

a) la información documentada requerida por este documento;

b) la información documentada que la organización determina como necesaria para la eficacia del SGCN.

Nota La extensión de la infonnación documentada para un SGCN puede diferir de una organización a otra debido a:
- el tamaño de la organización y el tipo de actividad, procesos, productos y servicios, y recursos;
- la complejidad de sus procesos y sus interrelaciones;
- la competencia de las personas.

7.5.2 Creación y actualización

Al crear y actualizar la información documentada, la organización debe asegurarse de que lo siguiente sea apropiado:

a) identificación y descripción (por ejemplo, título, fecha, autor o referencia numérica);

b) formato (por ejemplo, lenguaje, versión del software, gráfico) y medios de soporte (por ejemplo, papel, electrónico);

c) revisión y aprobación para conveniencia y adecuación.

7.5.3 Control de la información documentada

7.5.3.1 La información documentada que se requiere para el SGCN y por el presente documento debe ser controlada para asegurarse de que:

a) que esté disponible y sea idónea para su uso, cuando y donde se necesite;

b) que esté protegida adecuadamente (por ejemplo, de contra pérdida de confidencialidad, uso inadecuado, o pérdida de integridad).

7.5.3.2 Para el control de la información doct1mentada, la organización debe abordar las siguientes actividades, según corresponda:

a) distribución, acceso, recuperación y uso;

b) almacenamiento y preservación, incluyendo preservación de legibilidad;

c) control de cambios (por ejemplo, control de versión);

d) conservación y disposición.

La información documentada de origen externo que la organización determina como necesaria para la planificación y operación del SGCN debe identificarse, según sea apropiado, y controlar.

Nota El acceso puede implicar la decisión, de acuerdo con el permiso, para ver solamente la información, o el permiso y la autoridad para ver y hacer cambios en la información documentada.

8. OPERACIÓN

8.1 PLANIFICACIÓN Y CONTROL OPERACIONAL

La organización debe planificar, implementar y controlar los procesos necesarios para lograr los requisitos, y para implementar las acciones determinadas en el numeral 6.1, mediante:

a) el establecimiento los criterios para los procesos;

b) la implementación del control de los procesos de acuerdo con los criterios;

c) el mantenimiento de la información documentada en la medida necesaria para tener confianza en que los procesos se llevan a cabo según lo planificado.

La organización debe controlar los cambios planificados y revisar las consecuencias de los cambios no intencionados, tomando acciones para mitigar los efectos adversos, si es necesario.

La organización debe asegurar que los procesos subcontratados y la cadena de abastecimiento sean controlados.

8.2 ANÁLISIS DE IMPACTO AL NEGOCIO Y EVALUACIÓN DE RIESGOS

8.2.1 Generalidades

La organización debe:

a) implementar y mantener procesos sistemáticos para analizar el impacto empresarial y evaluar los riesgos de interrupción;

b) revisar el análisis de impacto al negocio y la evaluación de riesgos en intervalos planificados y cuando haya cambios significativos dentro de la organización o en el contexto en el cual opera.

Nota La organización determina el orden en el que se llevan a cabo el análisis de impacto al negocio y la evaluación de riesgos.

8.2.2 Análisis de impacto al negocio (BIA, por sus siglas en inglés)

La organización debe usar procesos para analizar el impacto empresarial para determinar los requisitos y prioridades de la continuidad de negocio. El proceso debe:

a) definir los tipos de impacto y criterios relevantes para el contexto de la organización;

b) identificar las actividades que soportan la provisión de productos y servicios;

c) usar los tipos de impacto y criterios para evaluar el impacto a lo largo del tiempo que resulten de una interrupción de esas actividades;

d) identificar el periodo de tiempo dentro del cual el impacto de no reanudar las actividades sería inaceptable para la organización;

Nota 1 Esto puede denominarse el período máximo tolerable de interrupción, MTPD, por sus siglas en inglés.

e) priorizar períodos de tiempo dentro del período identificado en el numeral d), para reanudar las actividades interrumpidas en una capacidad aceptable mínima especificada;

Nota 2 Este periodo de tiempo puede denominarse periodo de tiempo objetivo, RTO, por siglas en inglés.

f) usar este análisis para identificar actividades prioritarias;

g) determinar cuáles recursos se necesitan para soportar las actividades prioritarias;

h) determinar las dependencias, incluyendo socios y proveedores, y las interdependencias de las actividades prioritarias.

8.2.3 Evaluación de riesgos

La organización debe implementar y mantener un proceso de evaluación de riesgos.

Nota El proceso para la elaboración de riesgos se aborda en la norma ISO 31000

La organización debe:

a) identificar el riesgo de interrupción de las actividades prioritarias de la organización y de sus recursos requeridos;

b) analizar y evaluar los riesgos identificados;

c) determinar cuáles riesgos necesitan tratamiento.

Nota Los riesgos en este subnumeral se relacionan con la interrupción de las actividades de negocio. Los riesgos y las oportunidades relacionados con la eficacia del sistema de gestión se abordan en el numeral 6.1

8.3 ESTRATEGIAS PARA LA CONTINUIDAD DE NEGOCIO Y SOLUCIONES

8.3.1 Generalidades

La organización debe identificar y seleccionar las estrategias para la continuidad de negocio que considere opciones para antes, durante y después de una interrupción, basados en los resultados del análisis de impacto al negocio y la evaluación de riesgos. Las estrategias para la continuidad de negocio deben componerse de una o más soluciones.

8.3.2 Identificación de estrategias y soluciones

La identificación de las estrategias y soluciones debe basarse en la medida que estas:

a) logren los requisitos para continuar y recuperar las actividades prioritarias dentro del periodo de tiempo identificado y la capacidad acordada;

b) consideren el importe y tipo de riesgo que la organización puede o no asumir;

c) consideren los costos y los beneficios asociados.

8.3.3 Selección de estrategias y soluciones

La selección debe basarse en la medida que las estrategias y soluciones:

a) cumpla con los requisitos para continuar y recuperar las actividades prioritarias dentro del período de tiempo identificado y la capacidad acordada;

b) considere el importe y tipo de riesgo que la organización puede o no asumir;

c) considere los beneficios y costos asociados.

8.3.4 Requisitos de recursos

La organización debe determinar los requisitos de los recursos para implementar las soluciones para la continuidad de negocio seleccionada. Los tipos de recursos a considerar deben incluir, pero no limitarse a:

a) personas;

b) información y datos;

c) infraestructura física como edificios, lugares de trabajo, y otras facilidades y servicios asociados;

d) equipos y consumibles;

e) sistemas de tecnología de la información y comunicación (TIC);

f) transporte y logística;

g) finanzas;

h) socios y proveedores.

8.3.5 Implementación de soluciones

La organización debe implementar y mantener las soluciones para la continuidad de negocio seleccionadas para que puedan activarse cuando sea necesario.

8.4 PLANES Y PROCEDIMIENTOS PARA LA CONTINUIDAD DE NEGOCIO

8.4.1 Generalidades

La organización debe implementar y mantener esquemas de respuesta que permitan una advertencia oportuna y la comunicación a las partes interesadas relevantes. Debe brindar planes y procedimientos para gestionar la organización durante una interrupción. Los planes y procedimientos deben usarse cuando se requieren activar las soluciones para la continuidad de negocio.

Nota Hay diferentes tipos de procedimientos que comprenden los planes para la continuidad de negocio.

La organización debe identificar y documentar los planes y procedimientos para la continuidad de negocio basados en el resultado de las estrategias y soluciones seleccionadas.

Los procedimientos deben:

a) ser específicos con respecto a las medidas inmediatas que deben tomarse durante una interrupción;

b) ser flexibles para responder a las cambiantes condiciones internas y externas de una interrupción;

c) enfocarse en el impacto de los incidentes que potencialmente conduzcan a una interrupción;

d) ser efectivos minimizando el impacte a través de la implementación de las soluciones convenientes;

e) asignar las funciones y las responsabilidades para las tareas dentro de ellos.

8.4.2 Esquemas de respuesta

8.4.2.1 La organización debe implementar y mantener un esquema, identificando uno o más equipos responsables, para responder durante las interrupciones.

8.4.2.2 Las funciones y las responsabilidades de cada equipo y las relaciones entre ellos deben establecerse claramente.

8.4.2.3 En conjunto, los equipos deben ser competentes para:

a) evaluar la naturaleza y el alcance de una interrupción y su impacto potencial;

b) evaluar el impacto contra los límites predefinidos que justifican el inicio de una respuesta formal;

c) activar la respuesta conveniente para la continuidad de negocio;

d) planificar acciones que necesiten emprenderse;

e) establecer prioridades (la primera prioridad debe ser la seguridad de la vida);

f) monitorear los efectos de la interrupción y la respuesta de la organización;

g) activar las soluciones para la continuidad de negocio;

h) comunicarse con las partes interesadas relevantes, las autoridades y los medios.

8.4.2.4 Para cada equipo debe haber:

a) personal identificado y sus suplentes con las responsabilidades, autoridad y competencias necesarias para desempeñar la función designada;

b) procedimientos documentados para guiar sus acciones (ver numeral 8.4), incluyendo aquellos para la activación, operación, coordinación y comunicación de la respuesta.

8.4.3 Advertencia y comunicación

8.4.3.1 La organización debe documentar y mantener procedimientos para:

a) comunicar interna y externamente a las partes interesadas relevantes, incluyendo que, cuando, con quien y que comunicar;

Nota La organización puede documentar y mantener procedimientos para cómo, y bajo qué circunstancias, la organización se comunica con sus empleados y sus contactos de emergencia.

b) recibir, comunicar y responder a las comunicaciones de las partes interesadas, incluyendo cualquier sistema de asesoría nacional o regional o su equivalente;

c) asegurar la disponibilidad de los medios de comunicación durante la interrupción;

d) facilitar la comunicación estructurada con los organismos de socorro;

e) brindar detalles de la respuesta a los medios de comunicación de la organización después de un incidente, incluyendo una estrategia de comunicación;

f) registrar los detalles de la interrupción, las acciones realizadas y las decisiones tomadas.

8.4.3.2 Cuando sea necesario, debe considerarse e implementarse lo siguiente:

a) alertar a las partes interesadas potencialmente afectadas por una interrupción real o inminente;

b) asegurar la coordinación y comunicación adecuadas entre las múltiples organizaciones de respuesta;

Los procedimientos de comunicación y advertencia deben practicarse como parte del programa de ejercicios de la organización como se describe en el numeral 8.5.

8.4.4 Planes para la continuidad de negocio

8.4.4.1 La organización debe documentar y mantener planes y procedimientos para la continuidad de negocio. Los planes para la continuidad de negocio deben brindar orientación e información para ayudar a los equipos a responder en una interrupción y ayudar a la organización en la respuesta y recuperación.

8.4.4.2 En conjunto, los planes para la continuidad de negocio deben contener:

a) detalle de las acciones que los equipos tomarán para:

1) continuar o recuperar las actividades prioritarias dentro de los periodos de tiempo predeterminados;

2) monitorear el impacto de la interrupción y la respuesta de la organización hacia ella;

b) referencia de los límites predefinidos y los procesos para activar la respuesta;

c) procedimientos para permitir la oferta de productos y servicios en una capacidad acordada;

d) detalles para gestionar las consecuencias inmediatas de una interrupción teniendo en cuenta:

1) el bienestar de los individuos;

2) la prevención de nuevas pérdidas o la indisponibilidad de las actividades prioritarias;

3) el impacto en el medio ambiente.

8.4.4.3 Cada plan debe incluir:

a) propósito, alcance y objetivos;

b) funciones y responsabilidades del equipo que implementará el plan;

c) acciones para implementar las soluciones;

d) información de soporte necesaria para activar (incluyendo los criterios de activación), operar, coordinar y comunicar las acciones de los equipos;

e) interdependencias internas y externas;

f) requisitos de los recursos;

g) requisitos para los reportes;

h) un proceso para darse de baja.

Cada plan debe ser utilizable y estar disponible en el momento y lugar en el que se requiera.

8.4.5 Recuperación

La organización debe tener procesos documentados para restaurar y volver a las actividades empresariales a partir de las medidas temporales adoptadas durante y después de la interrupción.

8.5 PROGRAMA DE EJERCICIOS

La organización debe implementar y mantener un programa de ejercicios y pruebas para validar a lo largo del tiempo la eficacia de sus soluciones y estrategias para la continuidad de negocio.

La organización debe conducir ejercicios y pruebas que:

a) sean consistentes con los objetivos para la continuidad de negocio;

b) estén basados en escenarios adecuados que estén bien planificados con objetivos y propósitos claramente definidos;

c) desarrollen el trabajo en equipo, competencia, confianza y conocimiento para aquellos que tienen que desempeñar funciones en relación con las interrupciones;

d) validen las estrategias y soluciones para la continuidad de negocio a lo largo del tiempo;

e) produzcan reportes formalizados después de los ejercicios que contengan resultados, recomendaciones y acciones para implementar mejoras;

f) se revisen en el contexto de promoción de mejora continua;

g) se desarrollen en intervalos predeterminados y cuando hay cambios significantes dentro de la organización o el contexto en la cual opera.

La organización debe actuar de acuerdo con los resultados de los ejercicios y las pruebas para implementar cambios y mejoras.

8.6 EVALUACIÓN DE LA DOCUMENTACIÓN Y CAPACIDAD DE CONTINUIDAD DE NEGOCIO

La organización debe:

a) evaluar la pertinencia, idoneidad y eficacia del análisis de impacto al negocio, la evaluación del riesgo, estrategias, soluciones, planes y procedimientos;

b) realizar evaluaciones a través de revisiones, análisis, ejercicios, pruebas, reportes después de incidentes y evaluaciones del desempeño;

c) dirigir evaluaciones de la capacidad de continuidad de negocio de los socios y proveedores relevantes;

d) evaluar el cumplimiento de los requisitos regulatorios y legales vigentes, buenas prácticas industriales y la conformidad con sus políticas y objetivos de continuidad de negocio;

e) actualizar la documentación y los procedimientos de manera periódica.

Estas evaluaciones deben realizarse en intervalos predeterminados, después de un incidente o activación y cuando se presenten cambios significativos.

9. EVALUACIÓN DEL DESEMPEÑO

9.1 MONITOREO, MEDICIÓN, ANÁLISIS Y EVALUACIÓN

La organización debe determinar:

a) qué necesita seguimiento y medición;

b) los métodos de seguimiento, medición, análisis y evaluación necesarios para asegurar resultados válidos;

c) cuando y quien realizará el seguimiento y la medición;

d) cuando y quien realizara el análisis y la evaluación de los resultados del seguimiento y la medición.

La organización debe conservar la información documentada apropiada como evidencia de los resultados.

La organización debe evaluar el desempeño y la eficacia del SGCN.

9.2 AUDITORÍA INTERNA

9.2.1 Generalidades

La organización debe llevar a cabo auditorías internas en intervalos planificados para proporcionar información de si el SGCN:

a) es conforme con:

1) los requisitos propios de la organización para su SGCN;

2) los requisitos de este documento;

b) se implementa y se mantiene eficazmente.

9.2.2 Programa(s) de auditoría

La organización debe:

a) planear, establecer, implementar y mantener un o varios programas de auditoría incluya la frecuencia, los métodos, las responsabilidades, los requisitos de planificación y la elaboración de infromes, que deben tener en consideración la importancia de los procesos involucrados y los resultados de las auditorías previas;

b) definir los criterios de la auditoría y el alcance de cada auditoría;

c) seleccionar los auditores y llevar a cabo auditorías para asegurarse la objetividad y la imparcialidad de los procesos auditados;

d) asegurase de que los resultados de las auditorías se informen a la dirección pertinente;

e) conservar información documentada como evidencia de la implementación del programa de auditoria y de los resultados de las auditorías;

f) asegurar que las acciones correctivas adecuadas se tomen sin demoras injustificadas para eliminar las no conformidades detectadas y sus causas;

g) asegurar que las acciones de auditorías de seguimiento incluyan la verificación de las medidas adoptadas y la presentación de informes de los resultados de verificación.

9.3 REVISIÓN POR LA DIRECCIÓN

9.3.1 Generalidades

La alta dirección debe revisar el SGCN de la organización en intervalos predeterminados, para asegurar su continua pertinencia, idoneidad y eficacia.

9.3.2 Consideraciones de la revisión por la dirección

La revisión por la dirección debe considerar:

a) el estado de las acciones de revisiones por la dirección previas;

b) cambios de las cuestiones internas y externas que sean relevantes para el SGCN;

c) información del desempeño del SGCN, incluyendo tendencias en:

1) no conformidades y acciones correctivas;

2) seguimiento y resultados de la evaluación de medición;

3) resultados de auditoría;

d) retroalimentación de las partes interesadas;

e) la necesidad de cambios en el SGCN, incluyendo la política y los objetivos;

f) los procedimientos y los recursos que pueden usarse en la organización para mejorar el desempeño y la eficacia del SGCN;

g) información del análisis de impacto al negocio y el análisis de riesgos;

h) resultados de la evaluación de la documentación y capacidad de continuidad de negocio (ver numeral 8.6);

i) riesgos o asuntos no abordados de manera adecuada en cualquier evaluación de riesgos anterior;

j) lecciones aprendidas y acciones derivadas de las cuasi-errores e interrupciones;

k) oportunidades para el mejoramiento continuo.

9.3.3 Resultados de la revisión por la dirección

9.3.3.1 Los resultados de la revisión por la dirección deben incluir decisiones relacionadas con las oportunidades de mejoramiento continuo y cualquier necesidad de cambio en el SGCN para mejorar la eficiencia y eficacia, incluyendo lo siguiente:

a) variaciones en el alcance del SGCN;

b) actualización del análisis de impacto al negocio, evaluación de riesgos, estrategias y soluciones para la continuidad de negocio, y planes de continuidad de negocio;

c) modificación de los procedimientos y controles para responder a los asuntos internos y externos que puedan impactar el SGCN;

d) como se medirá la eficacia de los controles.

9.3.3.2 La organización debe conservar la información documentada como evidencia de los resultados de la revisión por la dirección. Debe:

a) comunicar los resultados de la revisióR por la dirección a las partes interesadas relevantes;

b) tomar las convenientes acciones relacionadas con esos resultados.

1O. MEJORAMIENTO

10.1 NO CONFORMIDAD Y ACCIÔN CORRECTIVA

10.1.1 La organización debe determinar las oportunidades de mejoramiento e implementar las acciones necesarias para lograr los resultados deseados del SGCN.

10.1.2 Cuando ocurra una no conformidad, la organización debe:

a) reaccionar ante la no conformidad, y cuando sea aplicable:

   1) tomar acciones para controlarla y corregirla;

   2) hacer frente a las consecuencias;

b) evaluar la necesidad de acciones para eliminar las causas de la no conformidad, con el fin de que no vuelvan a ocurrir en otro parte, mediante:

   1) la revisión de la no conformidad;

   2) la determinación de las causas de la no conformidad;

   3) la determinación de si existen no conformidades similares, o que potencialmente puedan ocurrir;

c) implementar cualquier acción necesaria;

d) revisar la eficacia de cualquier acción correctiva tomada;

e) si fuera necesario, hacer los cambios en el SGCN.

Las acciones correctivas deben ser apropiadas para los efectos de las no conformidades encontradas.

10.1.3 La organización debe conservar la información documentada como evidencia de:

a) la naturaleza de las no conformidades y cualquier acción tomada posteriormente;

b) los resultados de cualquier acción correctiva.

10.2 MEJORA CONTINUA

La organización debe mejorar de manera continua la conveniencia, adecuación y eficacia del SGCN, basado en las mediciones cualitativas y cuantitativas.

La organización debe considerar los resultados del análisis y la evaluación, y los resultados de la revisión de la dirección, para determinar si hay necesidades u oportunidades, relacionadas con la empresa, o el SGCN, que considerarse como parte de la mejora continua.

Nota La organización puede usar los procesos del SGCN, como el liderazgo, la planeación y la evaluación del desempeño, para mejorar.

BIBLIOGRAFÍA

[1] ISO 9001, *Qua/ity management systems. Requirements*

[2] ISO 14001, *Environmental management systems. Requirements with guidance far use*

[3] ISO 19011, *Guidelines far auditing management systems*

[4] ISO/IEC/TS 17021-6, *Canfarmity assessment. Requirements far badies providing audit and certificatian af management systems. Part 6: Campetence requirements far auditing and certificatian af business cantinuity management systems*

[5] ISO/IEC 20000-1, *Infarmatian technalagy. Service management. Part 1: Service management system requirements*

[6] ISO 22313, *Sacietal security. Business cantinuity management systems. Guidance*

[7] ISO 22316, *Security and resi/ience. Organizatianal resilience. Principies and attributes*

[8] ISO/TS 22317, *Sacietal security. Business cantinuity management systems. Guidelines far business impact analysis (BIA)*

[9] ISO/TS 22318, *Sacietal security. Busir:iess cantinuity management systems. Guidelines far supply chain cantinuity*

[1 0] ISO/TS 22330, *Security and resilience. Business cantinuity management systems. Guidelines far peaple aspects af business cantinuity*

[11] ISO/TS 22331, *Security and resilience. Business cantinuity management systems. Guidelines far business cantinuity strategy*

[12] ISO/IEC 27001, */nfarmatian technalagy. Security techniques. Infarmatian security management systems. Requirements*

[13] ISO/IEC 27031, *Infarmatian technalagy. Security techniques. Guidelines far infarmatian and cammunicatian techna/agy readiness far business cantinuity*

[14] ISO 28000, *Specificatian far security management systems far the supply chain*

[15] ISO 31000, *Risk management. Guidelines*

[16] IEC 31010, *Risk management. Risk assessment techniques*

[17] ISO Guide 73, *Risk management. Vacabulary*

DOCUMENTO DE REFERENCIA

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION, *Security and resilience. Business continuitymanagementsystems. Requirements.* Ginebra: ISO, 2019, 21 p (ISO 22301:2019).

Colombia

Apartadó
apartado@icontec.org

Armenia
armenia@icontec.org

Barranquilla
barranquilla@icontec.org

Barrancabermeja
barrancabermeja@icontec.org

Bogotá
bogota@icontec.org

Bucaramanga
bucaramanga@icontec.org

Cali
cali@icontec.org

Cartagena
cartagena@icontec.org

Cúcuta
cucuta@icontec.org

Manizales
manizales@icontec.org

Medellín
medellin@icontec.org

Montería
monteria@icontec.org

Ibagué
ibague@icontec.org

Neiva
neiva@icontec.org

Pereira
pereira@icontec.org

Pasto
pasto@icontec.org

Villavicencio
villavicencio@icontec.org

Resto del mundo

Bolivia
bolivia@icontec.org

Ecuador
ecuador@icontec.org

Honduras
honduras@icontec.org

Panamá
panama@icontec.org

Costa Rica
costarica@icontec.org

El Salvador
elsalvador@icontec.org

México
mexico@icontec.org

República Dominicana
republicadorninicana@icontec.org

Chile
chile@icontecorg

Guatemala
guatemala@icontec.org

Nicaragua
nicaragua@icontec.org

Perú
peru@icontec.org

Canales de atención al cliente:
Bogotá: **607 8888**
Resto del país: **01 8000 94 9000**
cliente@icontec.org
www.icontec.org

icontec.org